

NexusTech Solutions
Policy Overhaul Simulation

Task 1 Evidence Bundle 1: Security Policy Hierarchy

Hierarchy Definition Table

Document type	Purpose	Authority	Nature	Level of detail
Policy	States management intent and the rules everyone must follow, and why	Approved by the CEO and senior management	Mandatory	High level. Says what must happen, with no tools or steps. Changes rarely.
Standard	Sets specific, measurable requirements that support a policy	Issued under a policy. Approved by the Information Security Manager with the IT Director	Mandatory	Medium. Names values, settings and approved technologies.
Guideline	Gives advice and good practice to help people meet a policy or standard	Issued by Security or IT. Has no enforcement power of its own	Recommended	Medium. Explains options and tips.
Procedure	Gives step-by-step instructions to complete a task the same way every time	Owned by the team that performs the task. Must match policy and standards	Mandatory when doing the task	Very high. Exact actions, roles and tools. Changes often.

Categorisation of the Eight Statements

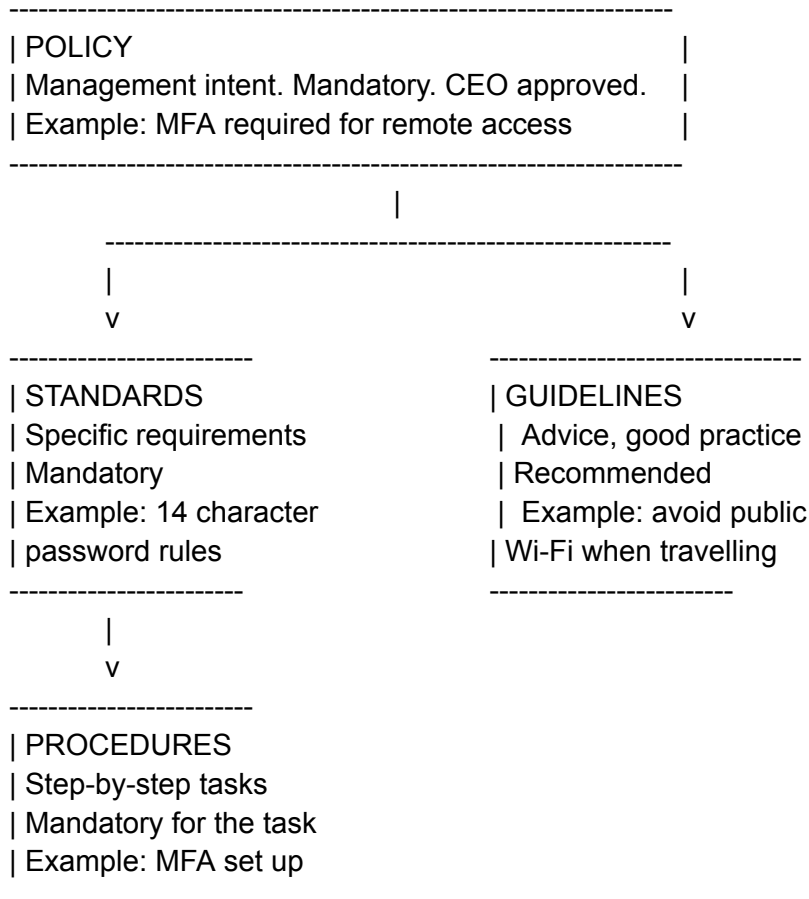
No.	Statement (short form)	Category	Justification
1	All employees must use MFA for remote access	Policy	It is a mandatory, high-level rule that names no tool and gives no steps.
2	Steps to set up MFA on a mobile device	Procedure	It lists the exact actions a user follows to complete one task.
3	Developers are recommended to use parameterised queries	Guideline	The word "recommended" makes it advice, and it should become a standard if secure coding must be enforced.
4	NexusTech is committed to protecting confidentiality, integrity and availability of client data	Policy	It states management intent and principle without technical detail.

No.	Statement (short form)	Category	Justification
5	Laptops must use BitLocker or FileVault full-disk encryption	Standard	It is mandatory but names specific technologies, which can change without changing the policy.
6	Employees should avoid public, unsecured Wi-Fi	Guideline	"Should avoid" is advisory and leaves the choice to the employee.
7	Contact the IT Helpdesk on extension 5555 during a suspected breach	Procedure	It gives a specific action and contact point for a specific event.
8	Passwords need 14 characters plus four character types	Standard	It is a mandatory, measurable requirement that supports a policy.

The existing "Password Policy" should be split into four documents:

- A short policy statement.
- A Password Standard (statement 8).
- A Password Reset Procedure containing the Active Directory steps.
- A guideline with tips on passphrases.

Hierarchy Diagram



Policy sets the rule. Standards make the rule measurable. Procedures explain how to carry out the work. Guidelines support all three but add no requirements.

Task 2 Evidence Bundle 2: Acceptable Use Policy

NexusTech Solutions: ACCEPTABLE USE POLICY

Title	Acceptable Use Policy
Document ID	NT-POL-AUP-01
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18th SEptember 2026
Review Date	17th September 2027

Version	Date	Author	Change
1.0	1 October 2026	Information Security Manager	First issue

1. Purpose

This policy sets the rules for using NexusTech information, devices, networks and services. It protects company and client data, reduces malware and compliance risk, and supports ISO/IEC 27001 and SOC 2 requirements (ISO/IEC, 2022a; AICPA, 2017).

2. Scope

This policy applies to all employees, contractors, interns, temporary staff and third parties who use NexusTech information assets. It covers company laptops, phones, servers, networks, cloud services, email, messaging tools, software and data, whether used in the office, at home or while travelling. Personal devices may access company data only where IT/Security has authorised it.

3. Policy Statements

Acceptable use

Users must use NexusTech assets mainly for authorised business purposes.

Users must protect their credentials, use MFA where required, and never share passwords or accounts.

Users must lock or log off devices when leaving them unattended.

Users must store and share company and client data only in systems approved by NexusTech.

Users must share confidential and client data only with people who are authorised and need it for their work.

Users must keep security tools on their devices active and allow updates to install. This includes antivirus, encryption and firewall.

Users must keep company devices physically secure, including while travelling.

Users must report lost devices, suspected malware, phishing and other suspected incidents to the IT Helpdesk immediately.

Users must follow applicable laws, software licences and client contract requirements when using company assets.

Prohibited activities

Users must not:

Download, install or run software, browser extensions or tools that are not on the approved software list.

Disable, bypass or tamper with security controls.

Copy, send or store company or client data in personal email, personal cloud storage, personal messaging accounts or removable media unless IT/Security has approved it.

Access, copy, change or delete data or systems without authorisation.

Connect unapproved devices to the corporate network.

Use another person's account or allow others to use theirs.

Create, view, store or send illegal, offensive, harassing, discriminatory or sexually explicit material.

Use company assets for gambling, cryptocurrency mining, illegal file sharing or running a personal business.

Run security scanning or testing tools unless the Information Security Manager has approved it in writing.

Reasonable personal use

Limited personal use of company devices and internet is allowed if it is brief and occasional and does not affect work or other users.

Personal use must not create security, legal or reputational risk, cause significant cost, or involve any prohibited activity in 3.2.

Personal use must never involve company or client data.

Personal files stored on company devices are kept at the user's own risk and may be removed if needed for security or repair.

Monitoring

NexusTech may monitor and log use of its assets, networks and accounts to protect security and check compliance, in line with applicable law. Users should not expect privacy when using company assets.

Roles and Responsibilities

Role	Responsibilities
All users	Read and acknowledge this policy, complete training, follow all statements, and report incidents immediately.
Line managers	Make sure their team knows and follows the policy, approve access only when the role needs it, report suspected breaches to Security and HR, and make sure assets are returned when staff leave.
IT/Security	Provide approved software and secure tools, maintain and monitor security controls, investigate incidents, assess exception requests and keep the exception register.
HR	Include this policy in onboarding and employment terms, record acknowledgements, and apply disciplinary action fairly and consistently.
Information Security Manager	Own, maintain and review the policy, and report compliance to the Information Security Steering Committee.
CEO	Approve the policy and give management support for its enforcement.

Compliance and Enforcement

Compliance will be checked through system logs, audits and management reviews. Breaches must be reported to the Information Security Manager and HR. Security may suspend access immediately when needed to contain a risk. Consequences match the seriousness of the breach and follow the HR disciplinary process. They range from retraining and a written warning to suspension, dismissal or contract termination. Legal action may follow where laws are broken. Repeated or deliberate breaches are treated as serious misconduct. Nobody will be penalised for reporting an incident in good faith.

Exceptions

Exceptions are allowed only in writing. The requester must submit a form to the Information Security Manager stating the business reason, the risk, the extra controls to be used and the time needed. The Information Security Manager and the relevant system or data owner must approve it, and high-risk exceptions also need the IT Director's approval. Exceptions last no longer than 12 months and end automatically unless renewed. All exceptions are recorded in an exception register that Security reviews every quarter. No exception may allow a breach of law or client contract.

Approval and Review

This policy is owned by the Information Security Manager and approved by Marcus Vance, CEO. It is reviewed every year and earlier after a major incident, major technology change, or change in law or client requirements. Related documents are the User Access Request Procedure, the Password Standard, the Incident Reporting Procedure and the HR Disciplinary Procedure.

Approved by	Signature	Date
Marcus Vance, CEO		

Task 3 Evidence Bundle 3: User Access Request Procedure

Title	User Access Request Procedure
Version	1.0
Procedure Owner	IT Director (Sarah Jenkins)
Approver	Information Security Manager
Supports	Acceptable Use Policy, ISO/IEC 27001 Annex A 5.15 and 5.18 (ISO/IEC, 2022b), SOC 2 logical access criteria CC6.1 to CC6.3 (AICPA, 2017)

1. Purpose and Scope

This procedure makes sure access to NexusTech systems is requested, approved and provisioned in a consistent and traceable way. It applies to Helpdesk technicians and to all requests for new, changed or temporary access for employees, contractors and third parties. Removing access when someone leaves follows a separate leaver procedure.

2. Prerequisites

- **Systems:** the approved ticketing system, the identity directory (for example Active Directory), the role-based access matrix, and HR records.
- **Approvals:** line manager approval for every request. Data or system owner approval for sensitive systems, client data and admin rights. Security approval for privileged access.
- **Authorised roles:** only Helpdesk technicians named on the authorised list may create accounts or change permissions.
- **For new users:** HR has confirmed the person's employment or contract, and the person has acknowledged the Acceptable Use Policy.

3. Procedure Steps

1. **Receive the request through a ticket only.** If a request arrives by email, chat or phone, do not act on it. Ask the requester to submit the access request form in the ticketing system.
2. **Check the ticket is complete.** It must show the user's full name, employee ID, job title, department, system and access level requested, business reason, manager name, and an end date for temporary access. Return incomplete tickets to the requester and do not proceed.
3. **Confirm the user's status.** Check HR records that the user is a current employee or an active contractor with a named sponsor. For new users, confirm that the AUP acknowledgement is recorded.
4. **Verify approvals.** Confirm that the approval is recorded inside the ticket workflow and comes from the user's line manager as shown in HR records. Do not accept forwarded emails or screenshots. A requester must never approve their own access. If the access is sensitive or privileged, confirm the data owner's or Security's approval as well.
5. **Apply the least-privilege check.** Compare the request against the role access matrix. Grant only what the role needs. If the request goes beyond the standard role profile, send it back for extra justification and owner approval. Do not copy access from another user's account.

6. **Create or update the account.** Use the standard naming format and create a unique account for one person. Shared or generic accounts are not allowed. Enrol the account in MFA. Never write passwords in the ticket or in email. Give the initial credentials to the user only, through the approved secure method, and require a password change at first login.
7. **Assign permissions by role.** Add the account to the security groups linked to the role. Do not grant permissions directly to the individual unless the exception is documented in the ticket. Set an expiry date for temporary access. Give admin rights only through a separate admin account.
8. **Verify the access.** Check that the account can reach only the approved systems. For privileged or sensitive access, a second technician must confirm the permissions.
9. **Notify the user and manager.** Update the ticket and email both people with the access granted, the expiry date if any, and a reminder to follow the AUP. Do not include passwords.
10. **Capture evidence and close the ticket.** Attach the approval record, a group membership export or screenshot, the date and time, the technician's name and the expiry date. Close the ticket only when all evidence is attached. Target completion is two working days after full approval.

4. Emergency or Exceptional Requests

Use this route only when a manager or on-call lead states that access is needed urgently to keep a critical service running or to resolve an incident.

1. Verify the caller's identity by calling back on the number in the HR directory.
2. Get verbal approval from the user's manager, or the on-call manager if the manager is unavailable.
3. Log an emergency ticket straight away and record who approved and when.
4. Grant the minimum access needed. It must expire within 24 hours.
5. Notify the Information Security Manager immediately.
6. Obtain written approval in the ticket within one working day.
7. The Information Security Manager reviews the case within two working days. Remove the access at expiry unless full approval has been recorded.

5. Record Retention and Audit Trail

- Keep tickets, approvals and evidence for at least three years, or longer if a client contract or law requires it.
- Do not edit or delete closed tickets. Corrections are added as new entries.
- Directory and system logs of account changes are kept and protected from alteration.
- Security checks a sample of closed tickets every month for missing approvals and excess permissions.
- Managers and data owners review who has access to their systems every quarter, and Security records the results.

Task 4 Evidence Bundle 4: Communication and Training Plan

Rollout Plan by Audience

Audience	Key message	Channel	Owner	Timing	Acknowledgement	Success measure
General employees	Use company devices and data only in approved ways. No unapproved software. Keep personal use limited. Report incidents at once. Breaches have consequences.	CEO announcement email, all-hands session, intranet page with summary and FAQ, mandatory 20-minute e-learning with knowledge check	CEO (announcement), Information Security Manager (content), HR (tracking)	Announcement Day 1, all-hands Week 1, training done by Week 3	Digital attestation after passing the knowledge check	95% attested by Week 3 and 100% by Week 5. Average quiz score of 80% or more.
Line managers	Model and enforce the AUP. Approve access and exceptions only with a business reason. Handle breaches through HR and Security.	45-minute briefing with a toolkit of talking points, FAQ and escalation steps	Information Security Manager and HR	Two weeks before announcement	Manager attestation and confirmation that a team briefing was held	100% briefed before Day 1. 100% of team briefings held by Week 2.
IT, Security and Helpdesk	Apply the AUP daily. Use the approved software list, log exceptions, act on access requests only through tickets and report breaches.	60-minute technical workshop, walkthrough of the access procedure, quick reference card	IT Director	One week before announcement	Attestation plus workshop attendance record	100% attendance. At least 90% correct in scenario check.

Audience	Key message	Channel	Owner	Timing	Acknowledgement	Success measure
HR	Add the AUP to onboarding, contracts and disciplinary practice. Apply consequences consistently.	Working session with the Information Security Manager, updated contract and onboarding templates	HR lead	Two weeks before announcement	Sign-off of updated onboarding pack	Templates updated before Day 1.
New joiners and contractors	The same rules apply from day one, before any access is given.	Onboarding pack, e-learning module, sponsor briefing	HR, hiring manager or contractor sponsor	Before account activation	Attestation recorded before first login	100% attested before access is granted.

Rollout Timeline

When	Activity
Two weeks before launch	Brief managers, IT and HR. Finish the e-learning module, FAQ and intranet page.
Day 1	CEO announcement email with link to the AUP summary.
Week 1	All-hands session. E-learning assigned to all staff.
Week 3	Deadline for e-learning and attestation.
Week 4	Reminders to overdue staff. Escalation begins.
Week 6	Five-question pulse check. Review of Helpdesk questions and common mistakes.
Month 3	Effectiveness report to the Information Security Steering Committee.
Every year and on joining	Refresher training and re-attestation.

Acknowledgement Mechanism

After completing the module and passing the knowledge check (pass mark 80%, two attempts), the user confirms with one click: "I have read, understood and agree to comply with the Acceptable Use Policy." The system records the name, date, time and policy version. HR and Security keep these records for audits. New joiners attest before account activation, and everyone re-attests each year and after a major policy revision.

Measures of Rollout Effectiveness

1. **Acknowledgement rate:** the percentage of users who have attested, against the targets above.
2. **Training completion and knowledge check results:** completion rate, first-attempt pass rate (target 90%) and questions most often answered wrongly.
3. **Behaviour change:** the number of unapproved software alerts and AUP-related incidents at Month 3 and Month 6, compared with the three months before rollout.

Escalation of Non-Compliance

- **Overdue training:** an automatic reminder is sent on the deadline. After 7 days overdue the manager is copied. After 14 days the manager meets the employee and HR is informed. After 21 days the Information Security Manager and HR may suspend non-essential access until the training is done, with the IT Director's approval.
- **Repeated misunderstanding:** a user who fails the knowledge check twice gets one-to-one coaching from Security or their manager before retaking it.
- **Wider confusion:** if many people miss the same question, Security revises the training or the policy wording.
- **Breaches:** confirmed breaches follow the enforcement section of the AUP through HR. Deliberate breaches go to HR directly

MEMO

To	Information Security Steering Committee
From	Information Security Manager
Date	October 2027
Subject	Review of the Acceptable Use Policy (Version 1.0)

Two events require a review of the Acceptable Use Policy before the annual date. First, the primary database has moved to AWS. Client data is now held in a cloud environment with new administrator access, and Version 1.0 was written mainly for company devices and the corporate network. It does not cover cloud services, cloud administration or the shared responsibility with the provider, which matters for our financial and healthcare clients. Second, an employee shared a sensitive document through a personal cloud storage account. This shows that the rule on approved storage was not clear enough or not well understood, and it meets the policy's own trigger for a review after an incident.

The review will be led by the Information Security Manager in three parts. Stakeholder consultation will include the IT Director, cloud and DevOps engineers, HR, data owners, client-facing managers and a sample of employees. Risk analysis will update the risk register for cloud data exposure and data leakage, and compare the policy against ISO/IEC 27001 Annex A controls 5.10, 5.23 and 8.12 (ISO/IEC, 2022b). Evidence review will cover the incident report and root cause, cloud and network logs, training records, the exception register, client contract clauses and audit findings. I propose at least two changes:

1. **Approved cloud services.** Company and client data may be stored or shared only in cloud services on an approved register, including the AWS environment. Personal cloud storage, personal email and personal messaging apps are named as prohibited. Sharing links must go to named recipients and expire.
2. **Cloud administration.** Cloud console access must use named accounts with MFA. Admin accounts must be used only for admin tasks. Access keys must never be shared or stored in code repositories or personal storage.

I also propose a duty to report accidental sharing immediately.

The policy owner remains the Information Security Manager. The revised version, 2.0 because the changes are material, will be drafted by the Information Security Manager and checked by the IT Director, HR and the data owners. It will then be reviewed and recommended by this Committee and given final approval by the CEO. After approval we will publish it, brief staff on the changes and collect fresh attestations. I recommend a full review every 12 months. I also recommend an early review after any of these events:

- A security incident involving an AUP breach that exposes client data.
- A major change in infrastructure or cloud provider.
- A change in law or client contract terms.

-
- A significant audit finding from an ISO/IEC 27001 or SOC 2 assessment.

References

AICPA (2017) *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*. New York: American Institute of Certified Public Accountants.

ISO/IEC (2022a) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection: Information security management systems: Requirements*. Geneva: International Organization for Standardization.

ISO/IEC (2022b) *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection: Information security controls*. Geneva: International Organization for Standardization.